

1. Assess whether management maintains policies, standards, and procedures that guide the change control process, including defined roles and responsibilities of key personnel in the change control process. Consider management's actions to
 - a. Designate personnel with the ability to create or initiate a request for a change and provide the processes they should follow.
 - b. Designate an individual (e.g., change manager) to facilitate a change who is responsible for managing all changes affecting the entity with minimal or no disruptions to operations.
 - c. Consider using a group of stakeholders that can aid the change manager in the assessment, prioritization, and scheduling of changes.
 - d. Prioritize and categorize changes.
 - e. Implement a method to track and report changes (e.g., standard change request forms, library and version controls, and spreadsheets or automated change logs).
2. Assess management's defined change control process to make routine and planned changes to systems or components, adjust configuration settings, and make changes to remediate flaws. Consider management's actions to
 - a. Follow a defined change control process to make routine and planned changes to systems or components, adjust configuration settings, and make changes to remediate flaws.
 - b. Account for
 - Emergency and unscheduled changes in the change control process.
 - Preparations for unexpected problems or failures with the change by defining a back-out plan and documenting the steps taken during the change in the order they occurred.
 - Requests for change.
 - Review of changes.
 - Approval of changes.
 - Design and build of changes.
 - Testing of changes.
 - Implementation of changes.
 - Verification of changes and close of the change process.
 - c. Follow processes, after verification of changes, to document completion of the change and close the change request.
 - d. Report on the status of the change after closing and monitor the implemented change for unintended issues.
 - e. Integrate security into its change control processes to help ensure that modifications do not adversely affect the security posture of varying systems.
 - f. Define the implementation plan (i.e., steps to deploy the change), create a full copy of the current version in production, and finalize the back-out plan before deploying the change.
 - g. Perform a post-implementation review to verify that the change was deployed according to the implementation plan and functions appropriately.

- h. Follow processes after verification to document completion of the change and close the change request.
 - i. Report on the status of the change after closing and monitor the implemented change for unintended issues.
3. Assess additional controls in change management. Consider management's actions to
 - a. Isolate and protect the testing environment to avoid it being a vulnerable vector for exploit in the entity.
 - b. Strictly control the movement of programs and files among development, quality management, and production libraries for purposes of change control.
 - c. Assign librarian functions to independent personnel, such as quality management personnel in larger, or more complex entities, or to nonoperations personnel in smaller or less complex entities.
 - d. Validate that library attributes include an auditable activity log with appropriate controls to ensure that information has not been altered or deleted.
 - e. Implement library controls, such as
 - Automated access controls.
 - Automated library applications.
 - f. Consider using these automated change controls commensurate with the complexity of the entity's IT environment and the number, types, and complexities of changes in that environment.
 - g. Strictly control access to production software libraries, particularly in distributed environments, regardless of whether the entity has automated change control tools.
 - h. Establish appropriate policies for the use of code repositories, such as determining what code repositories they use and where code repository data actually resides, especially for any cloud-based repositories (e.g., public, private, and community clouds).
 - i. Conduct periodic reconnaissance of open (i.e., public) code repositories for personal employee accounts and unauthorized posting of company-owned source code.
 - j. Use available version control features to track changes made to the code in the repository, providing accountability to the individual account that made the changes.
 - k. Implement access control processes, such as the following:
 - Request and approval processes for access to code repositories (e.g., development, staging, or production).
 - Appropriate access controls, such as use of MFA for employee access to all (internal and cloud-based) code repositories.
 - Appropriate segregation of duties to prevent developer access to the staging and production code repositories, prevent quality management personnel from having access to production code repositories, and grant access to production code repositories only to release management personnel.
 - Periodic review processes for access roles and repository logs.
4. Assess management's oversight of change or modification types. Consider management's actions to

- a. Develop procedures for changes that include change request, review, and approval that direct management to plan, test, and document changes before implementation.
 - b. Validate that changes to any IT system, component, or service are supported by an orderly, adaptable, documented, and measurable process to promote the consistent implementation of changes and provide an audit trail for changes, regardless of the change type.
 - c. Train personnel involved in changes to ensure that those changes support entity objectives and do not adversely affect confidentiality, integrity, availability, and resilience.
 - d. Coordinate change management for routine modifications, as IT changes often affect multiple business lines.
 - e. Develop an inventory of changes, including routine modifications, for back-out, resilience, and tracking purposes.
5. Assess management's oversight of planned changes. Consider management's actions to
 - a. Perform a risk assessment for all major modifications and significant security-related changes.
 - b. Discuss requests for major modifications formally and assign appropriate key stakeholders or committees to have responsibility for approving the requests, based on predefined criteria.
 - c. Define the entity's training requirements associated with conversions or major hardware and software upgrades.
 - d. Evaluate the type, volume, and timing of training needs for each affected line of business and coordinate training programs with applicable third parties.
 - e. Plan when a conversion affects a core platform supporting business operations whether managed on-premises or at a third party to minimize conversion issues and costs.
 - f. Consider costs related to deconversions, system and component upgrades, and training for changes with the new system.
 - g. Effectively manage conversions beginning with due diligence, including a comprehensive analysis of a conversion's impact on existing operations (e.g., processing, storage, and communication requirements), while accounting for interdependencies.
 - h. Establish communication procedures, reporting needs, and lines of authority for timely decision-making and issue resolution, when working with a third-party partner.
 - i. Coordinate with conversion partners to consider the entity's conversion needs.
6. Assess management oversight of emergency modifications. Consider management's actions to
 - a. Maintain appropriate implementation control standards, although an emergency modification should be completed quickly.
 - b. Periodically review the change control processes to optimize efficiency and determine whether they need revision.

- c. Perform testing before deployment in the case of an emergency change, if possible, as untested changes may cause even more damage than the initial risk being mitigated.
- d. Evaluate whether the potential damage resulting from an untested emergency change outweighs the immediate damage from the identified risk to determine the appropriateness of the decision to implement the emergency change.
- e. Develop a process for system and component owners to identify all sources of change to help ensure that emergency modifications go through the change control process, even if it is after the fact.
- f. Accelerate change management processes to implement changes rapidly to effectively mitigate the impact of emergency situations.
- g. Develop effective processes to address emergency situations.
- h. Strategically plan for emergency modifications, including budgeting contingency funds for execution and management of emergency situations.
- i. Consider appropriate measures to help effectively implement changes during emergencies. Examples include the following:
 - Organize a group (e.g., emergency change control review board) that can meet on extremely short notice to approve changes that need immediate implementation. The group could include senior leadership, management of critical lines of business, and management of key IT areas.
 - Plan for multiple methods of meeting (e.g., in-person, phone, and virtual) in case the emergency occurs outside normal business hours.
 - Create an emergency modification implementation plan that includes a list of individuals in the emergency group (e.g., emergency change control review board) and a list of procedures that are modified from standard change control and security processes.
 - Compress certain phases of the implementation process to save time but still perform testing and modeling or simulation before releasing the changes into the production environment.
 - Discuss and implement minimum recovery point objectives with stakeholders for emergencies to reduce the time required to perform backups of systems to adequately implement an emergency modification.
 - Define and use emergency downtime procedures (e.g., failover to alternate systems) that allow systems to be taken completely offline in emergencies.
 - Follow emergency procedures, such as use of “out-of-band” communication provisions, if normal channels for secure transmission of information becomes unavailable.
 - Leverage senior management to communicate the urgency of emergency modifications and help achieve rapid consensus for decisions affecting the change implementation timeline.
 - Perform periodic emergency drills in the test and modeling environment to prepare IT staff to deal with the stress of emergency modifications. Review the results of these drills and document lessons learned.
- j. Plan for emergency modifications, such as doing the following:
 - Establish who can declare an emergency and facilitate decision-making during emergencies.

- Designate individuals who can approve emergency changes and maintain contact information.
 - Develop a plan that outlines the responsible parties and procedures for enacting emergency changes.
 - Identify personnel responsible for change testing and implementation, as well as for initiating a back-out plan if implementation fails.
 - k. Validate every emergency modification after implementation to determine whether it was correctly classified, in order to keep the number of emergency modifications to a minimum.
 - l. Review reports of emergency modifications periodically for appropriateness of classification.
 - m. Control attempts by personnel to circumvent routine modification or planned change control processes by classifying changes as emergencies to avoid resource constraints (e.g., time, personnel, and cost).
 - n. Complete evaluations and documentation reviews of emergency modifications as soon as possible after implementation.
7. Assess management's change management documentation practices. Consider management's actions to
- a. Maintain documentation to track all changes (e.g., configuration settings, patches applied, system conversions, and emergency modifications) to systems and components.
 - b. Maintain appropriate documentation to support the impact analysis.
 - c. Prepare for the possibility of a failed or incomplete deployment and have procedures to address the issues and develop rollback or back-out procedures to reverse a failed deployment.
 - d. Consider the time required to perform rollback procedures, when to trigger the rollback plan, and how long it may take to roll back.
 - e. Determine whether the rollback plan can be accomplished in the defined timeline for the maintenance action.
 - f. Implement appropriate security controls to prevent unauthorized rollback.
 - g. Track and report issues that lead to the use of a back-out plan and the effects of a failed or incomplete change deployment.

Objective 15: Communicate and discuss findings, conclusions, and corrective actions.

1. Review preliminary conclusions with the examiner-in-charge regarding
 - a. Violations of law and regulation.
 - b. Significant issues warranting inclusion as matters requiring attention or recommendations in the report of examination.
 - c. Proposed Uniform Rating System for Information Technology management component rating and the potential impact of the examiner's conclusions on composite or other component IT ratings.
 - d. Potential impact of the examiner's conclusions on the entity's risk assessment.

2. Discuss findings with management and obtain proposed corrective action for significant deficiencies.
3. Document conclusions in a memorandum to the examiner-in-charge that provides report-ready comments for all relevant sections of the report of examination and guidance to future examiners.
4. Organize work papers to ensure clear support for significant findings by examination objective.

APPENDIX B: GLOSSARY

The purpose of the glossary is to define technical terms used in the *FFIEC IT Examination Handbook* booklets in the context of supervisory activities for the entities over which FFIEC members may have supervisory authority. The FFIEC members strive to align terminology in the glossary with appropriate authoritative standards, including the [NIST Computer Security Resource Center Glossary](#) (NIST Glossary) as the primary source for cyber-related definitions, as appropriate. FFIEC members employed the following process to select, modify, or develop definitions.

When a NIST definition existed:

- If NIST had a defined term and modifications to the definition were unnecessary, the FFIEC members included the NIST definition in this glossary. When multiple NIST definitions were available for the same term, the FFIEC members selected a definition for supervisory purposes.
- If NIST had a defined term, but the definition needed additional clarity for supervisory purposes to assist with the identification of safety and soundness and enterprise risks related to IT, the FFIEC members included both the NIST definition and the FFIEC-adapted definition. These definitions are labeled “FFIEC Adapted for Supervisory Purposes” in this glossary’s source column.

When a NIST definition did not exist, or the definition was not appropriate for supervisory purposes:

- If NIST did not have a defined term, but there was an appropriate authoritative third-party source (e.g., the ISO Glossary), the FFIEC members included that authoritative definition.
- If NIST did not have a defined term and there was not an appropriate authoritative third-party source, the FFIEC members developed a definition for supervisory purposes. These definitions are labeled “FFIEC Developed for Supervisory Purposes” in this glossary’s source column.

Due to the constantly evolving nature of IT and its associated risks, the FFIEC members may update definitions to maintain alignment with other government agencies and the financial services industry.

Table 5: Glossary of Terms for Development, Acquisition, and Maintenance

Term	Definition	Source
A		
Access control	Procedures and controls that limit or detect access to critical information resources. This can be accomplished through software, biometrics devices, or physical access to a controlled space.	NIST Glossary
Acquisition	All stages of the process of acquiring a product or services, beginning with the process for determining the need for the product or services and ending with contract completion and closeout.	NIST Glossary
Application	A system for collecting, saving, processing, and presenting data by means of a computer. The term “application” is generally used when referring to a component of software that can be executed. The	NIST Glossary

Term	Definition	Source
	terms “application” and “software application” are often used synonymously.	
Application programming interface (API)	A system access point or library function that has a well-defined syntax and is accessible from application programs or user code to provide well-defined functionality.	NIST Glossary
	Software code that allows two or more different programs to communicate with each other.	FFIEC Adapted for Supervisory Purposes
Architecture	Refers to the manner in which the strategic design of the hardware and software infrastructure components (e.g., devices, systems, and networks) are organized and integrated to achieve and support the entity’s business objectives.	FFIEC Developed for Supervisory Purposes
Artificial intelligence (AI)	Refers to the ability of machines to perform tasks that normally require human intelligence—for example, recognizing patterns, learning from experience, drawing conclusions, making predictions, or taking action—whether digitally or as the smart software behind autonomous physical systems.	U.S. Department of Defense, <i>Summary of the 2018 Department Of Defense Artificial Intelligence Strategy</i>
Assembler	A computer program that automatically converts instructions written in assembly language into machine language.	Merriam-Webster
Attack surface	The set of points on the boundary of a system, a system component, or an environment where an attacker can try to enter, cause an effect on, or extract data from, that system, component, or environment.	NIST Glossary
Authentication	A process that establishes the source of information, provides assurance of an entity’s identity or provides assurance of the integrity of communications sessions, messages, documents or stored data.	NIST Glossary
	A process designed to establish the source of the information, validity of a transmission, message, or originator, or a means of verifying an individual’s authorization to receive specific categories of information.	FFIEC Adapted for Supervisory Purposes
Authorization	The granting or denying of access rights to a user, program, or process.	NIST Glossary
Availability	Ensuring timely and reliable access to and use of information.	NIST Glossary
B		
Backdoor	An undocumented way of gaining access to a computer system. A backdoor is a potential security risk.	NIST Glossary
Backup	A copy of files and programs made to facilitate recovery, if necessary.	NIST Glossary
Barcode	An optical machine-readable representation of data about an object.	NIST, “Automated Identification Technologies for Forensic Science”
Baseline configuration	A set of specifications for a system, or configuration item within a system, that has been formally reviewed and agreed on at a given point in time, and which can be changed only through change control procedures. The baseline configuration is used as a basis for future builds, releases, and/or changes.	NIST Glossary
Big data	Extensive datasets—primarily in the characteristics of volume, variety, velocity, and/or variability—that require a scalable architecture for efficient storage, manipulation, and analysis.	NIST SP 1500-1r2, <i>NIST Big Data Interoperability Framework: Volume 1, Definitions</i>
Blockchain	A distributed digital ledger of cryptographically signed transactions that are grouped into blocks. Each block is cryptographically linked to the previous one (making it tamper evident) after validation and undergoing a consensus decision. As new blocks are added, older	NIST Glossary

Term	Definition	Source
	blocks become more difficult to modify (creating tamper resistance). New blocks are replicated across copies of the ledger in the network, and any conflicts are resolved automatically using established rules.	
Bounded context	In relation to microservices, it refers to having limited responsibility and dependence on other services.	NIST SP 800-204, Security Strategies for Microservices-Based Application Systems
Business case	A business case defines the value a project will deliver.	Project Management Institute (PMI), "Is This Really Worth the Effort? The Need for a Business Case"
	An evaluation of the benefit, cost, feasibility, and risk of alternative options to justify undertaking a project, program, or portfolio and define the value it will deliver.	FFIEC Adapted for Supervisory Purposes
C		
Capacity management	The process of planning and monitoring an entity's technology resources to support current and future strategic objectives.	FFIEC Developed for Supervisory Purposes
Central processing unit (CPU)	Computer hardware that houses the electronic circuits that control/direct all operations of the computer system.	Information Systems Audit and Control Association (ISACA) Glossary
Change control	Change control is the process through which all requests to change the approved baseline of a project, program, or portfolio are captured, evaluated and then approved, rejected, or deferred.	Association for Project Management
	Change control is the process through which all requests to change the approved baseline of a project, program, or portfolio are documented, evaluated and then approved, rejected, or deferred. Change control is an element in an overall change management process.	FFIEC Adapted for Supervisory Purposes
Change control board (CCB)	A group of qualified people with responsibility for the process of regulating and approving changes to hardware, firmware, software, and documentation throughout the development and operational life cycle of an information system. Also referred to as a configuration control board.	NIST Glossary
Change management	The continuous process of maintaining the integrity of hardware, software, firmware, and documentation and controlling and approving changes (e.g., addition, modification, or elimination) to information or technology assets or related infrastructure (aka configuration and change management).	CISA, CRR Supplemental Resource Guide, Volume 3: Configuration and Change Management, Version 1.1
Checksum	A value computed on data to detect error or manipulation.	NIST Glossary
Circuit	A dedicated single connection between two end points on a network.	NIST Glossary
Cloud access security broker	A software tool or service that sits between an entity's on-premises infrastructure and a cloud service provider's infrastructure as a "gatekeeper" to monitor activity and enforce the entity's security policies (e.g., authentication, single sign-on, authorization, credential mapping, and encryption) as the cloud-based resources are accessed.	FFIEC Developed for Supervisory Purposes
Cloud computing	A model for enabling ubiquitous, convenient, on-demand network access to a shared pool of configurable computing resources (e.g.,	NIST Glossary

Term	Definition	Source
	networks, servers, storage, applications, and services) that can be rapidly provisioned and released with minimal management effort or service provider interaction.	
Cloud service provider	A cloud service provider, or CSP, is a company that offers some component of cloud computing; typically, when you search the internet a cloud service is defined as infrastructure as a service (IaaS), software as a service (SaaS), or platform as a service (PaaS) to other businesses or individuals.	Cloud Security Alliance
	A third-party service provider who offers clients services over the public internet. Examples of services could be applications (SaaS), operating systems (PaaS), or infrastructure (IaaS).	FFIEC Adapted for Supervisory Purposes
Code	See machine code.	
Commercial off-the-shelf (COTS) software	A software and/or hardware product that is commercially ready-made and available for sale, lease, or license to the general public. Also referred to as off-the-shelf.	NIST Glossary
Compiled	Processed through software that translates a complete set of high-level computer instructions into machine language before executing any of them.	Merriam-Webster
Component	A unique part of a system that is needed to do something, perform a function, or finish a product.	Black's Law Dictionary
	A unique part of a larger system, such as hardware, software, and firmware, that is a building block to do something, perform a function, or finish a product.	FFIEC Adapted for Supervisory Purposes
Compromise	The unauthorized disclosure, modification, substitution, or use of sensitive data (e.g., keying material and other security-related information).	NIST Glossary
Confidentiality	The property that sensitive information is not disclosed to unauthorized entities.	NIST Glossary
Configuration	The selection of one of the sets of possible combinations of features of a system.	NIST Glossary
	The selection of combinations of conditions, parameters, features, and specifications of a system.	FFIEC Adapted for Supervisory Purposes
Configuration control board (CCB)	A group of qualified people with responsibility for the process of regulating and approving changes to hardware, firmware, software, and documentation throughout the development and operational life cycle of an information system. Also referred to as a change control board.	NIST Glossary
	A collection of activities focused on establishing and maintaining the integrity of information technology products and systems, through control of processes for initializing, changing, and monitoring the configurations of those products and systems throughout the system development life cycle.	FFIEC Adapted for Supervisory Purposes
Configuration settings	The set of parameters that can be changed in hardware, software, or firmware that affect the security posture and/or functionality of the information system.	NIST Glossary
Container	A container is a standard unit of software that packages up code and all its dependencies, down to, but not including the operating system (OS). It is a lightweight, standalone, executable package of software that includes everything needed to run an application except the OS: code, runtime, system tools, system libraries, and settings.	DOD Enterprise DevSecOps Reference Design: Version 1.0
Container image	A package that contains all the files required to run a container.	NIST SP 800-190, Application Container Security Guide